

POLICY FRAMEWORK HIERARCHY

Tier	Document Type	Definition	Purpose	Example (From GreenLeaf)	Audience
1	Policy	A high level, mandatory statement of intent	Sets the expectation and answers “What must we do?” And “Why?”	Greenleaf shall enforce MFA for all admin access	CEO, Board, Executive Leadership
2	Standard	A Specific, measurable, technical rule	Defines the requirement and answers “How exactly?” And “How much?”	MFA must be enforced using TOPT(e.g. Google Authenticator) for all AWS console logins. Passwords must be 12-15 characters and checked against breach database.	CTO, IT Team, System Admins
3	Procedure	A step by step guid	Provides the instructions and answers “Who does what and when?”	Step 1: New admin logs into AWS Step 2: Navigate to IAM Step 3: Enable MFA device using Google authenticator	Helpdesk, New Employees, End Users

<u>Rule</u>	<u>Why It Matters</u>
You cannot skip a tier.	A Policy without a Standard is unenforceable. A Standard without a Procedure is unexecutable. A Procedure without a Policy has no authority.
Each tier serves a different audience.	The CEO does not need to read the Procedure. The Helpdesk does not need to read the Policy. By separating them, you ensure the right people read the right documents.
Auditors check all three.	An auditor will look for the Policy (to see the mandate), the Standard (to see the measurable requirement), and the Procedure (to see if employees have clear instructions).